📘 DAY 1 — Cyber Security + Vulnerability + Linux (DEEP DIVE)

🔐 1. Cyber Security Foundations (DEEP)

What to Study

- CIA Triad
    - **Confidentiality**: encryption, access control
    - **Integrity**: hashing, checksums, immutability
    - **Availability**: rate limiting, redundancy, DoS protection
- Threat vs Vulnerability vs Risk
- Attack surface
- Defense in Depth
- Principle of Least Privilege

You MUST Understand

- Security is about **reducing blast radius**, not eliminating risk
- Every exposed service increases attack surface
- Security failures are often **misconfigurations**, not hacks

Likely Questions

- “What is security in a backend system?”
- “How do you design a secure system?”

How You Answer

Structure:

1. Identify threats
2. Reduce attack surface
3. Secure communication
4. Monitor and respond

🛑 2. OWASP Top 10 (IN DEPTH – CORE ONES)

A. Injection (SQL / NoSQL)

Study

- How injection happens
- Why string concatenation is dangerous
- SQL vs NoSQL injection differences

Mitigation

- Prepared statements
- ORM usage
- Input validation
- Least privilege DB users

Expected Question

“How do you prevent SQL injection?”

B. Broken Authentication

Study

- Weak passwords
- Token theft
- Session fixation
- Token replay

JWT Angle

- Short expiry
- Secure storage
- Refresh token rotation

C. Security Misconfiguration (VERY COMMON)

Study

- Open ports
- Default credentials
- Debug mode in prod
- Exposed admin endpoints

This is IMPORTANT

Most Nessus findings fall here.

D. Sensitive Data Exposure

Study

- Encryption at rest vs in transit
- TLS
- Logging sensitive data

Real-world Examples

- Logging JWT tokens
- Storing passwords in plaintext
- Exposing stack traces

E. XSS (Basic but Expected)

Study

- Stored vs Reflected XSS
- Why backend must sanitize
- Output encoding

🔑 3. JWT & API Security (VERY DEEP)

JWT Internals

- Header → algorithm
- Payload → claims
- Signature → integrity

MUST KNOW

- JWT ≠ encryption
- JWT is stateless
- Token invalidation challenges

Common JWT Mistakes

- Long expiry
- Storing in localStorage
- No refresh mechanism
- Weak signing key

Questions They May Ask

- “Is JWT secure?”
- “How do you invalidate JWT?”
- “Where do you store JWT?”

Answer Like a Pro

- Short-lived access tokens
- Refresh tokens
- HTTPS always
- Rotation & revocation strategy

🛡️ 4. Nessus & Vulnerability Management (IN DEPTH)

What Nessus Does

- Port scanning
- OS fingerprinting
- Vulnerability database checks
- Config compliance

Vulnerability Lifecycle (VERY IMPORTANT)

Detect → Validate → Prioritize → Mitigate → Verify

CVSS Score

- 0–3: Low
- 4–6: Medium
- 7–8: High
- 9–10: Critical

Mitigation Types

- Patch (best)
- Configuration change
- Firewall rule
- Compensating control
- Risk acceptance

Interview Expectation

They want to see:

- You can **read results**
- You can **prioritize**
- You don't blindly panic

🐧 5. Linux Fundamentals (IN DEPTH)

Process Management

- ps aux
- top
- kill
- Zombie vs orphan processes

Memory & Disk

- free -m
- df -h
- du -sh

Networking

- netstat -tulpn
- ss -tulpn
- Ports vs services

Log Analysis

- grep

- tail
- less
- Searching errors in huge logs

🔐 6. Linux Security Concepts

File Permissions

- r/w/x
- chmod numeric vs symbolic
- chown

Users & Privileges

- root vs sudo
- Principle of least privilege

SSH

- Password vs key-based auth
- Why keys are safer

📘 DAY 2 — Java + Automation + Secure Systems Thinking

☕ 7. Java Core (SECURITY & SYSTEMS FOCUS)

JVM

- Heap vs Stack
- GC basics
- Why memory leaks are dangerous

Exception Handling

- Checked vs unchecked
- Why exposing stack traces is bad
- Custom exceptions

Collections

- HashMap internals (basic)

- Thread-safety issues

🔄 8. Multithreading & Concurrency

Core Concepts

- Race conditions
- Synchronization
- Deadlocks
- Thread pools

Security Angle

- Race conditions can cause data corruption
- Improper locking can expose sensitive data

🧪 9. Secure Coding Practices (VERY IMPORTANT)

Must Know

- Input validation
- Output encoding
- Secure defaults
- Fail securely
- Avoid hardcoded secrets

Logging Best Practices

- Mask sensitive data
- Structured logs
- Log levels

⚙️ 10. Automation, CI/CD & Security

Git

- Branching strategy
- Merge conflicts

- Code reviews as security gate

CI/CD

- Automated builds
- Automated tests
- Security scans
- Dependency vulnerability checks

Shift Left Security

- Catch issues before production

🧠 11. Software Automation (GENERAL)

Concepts

- Why automate
- What to automate
- Where humans still needed

Examples

- Test automation
- Security scans
- Deployment pipelines

🗄️ 12. Databases & PL/SQL (SECURITY VIEW)

SQL Basics

- Joins
- Indexing
- Transactions

Security

- SQL injection
- Least privilege DB users
- Secure connections

🧩 13. Incident Response & Production Ownership

Learn This Flow

Detect → Analyze → Contain → Fix → Postmortem

They May Ask

- “What do you do during a security incident?”
- “How do you handle production failures?”

Your Strength

You already have **production ownership** — use it.

🎤 14. Behavioral & System Thinking

Prepare stories on:

- Production outage
- Performance improvement
- Security concern
- Debugging nightmare
- Cross-team coordination

Always include:

- Metrics
- Impact
- Learning

🎯 Final Advice (VERY IMPORTANT)

You don’t need to say:

“I am a cyber security expert”

You SHOULD say:

“I build production systems with security, reliability, and performance in mind.”

That mindset is exactly what Quest Global wants.

If you want next:

- 📄 **Printable checklist**
- 🎯 **Quest Global mock interview**
- 🧠 **Deep Nessus Q&A**
- 🔥 **Cyber security answers tailored to YOUR resume**

Say the word and we go deeper 💪